

Narrativa explicativa del marco GQM + PRAGMATIC aplicado a SSVc

Resulta tentador lanzar métricas como quien lanza confeti y luego, cuando llegan los reguladores, descubrir que no hay forma de demostrar que todo ese colorido sirve para algo. El objetivo de combinar GQM con PRAGMATIC es precisamente evitar ese síndrome del “dashboard ornamental”. [web:24][web:19][web:27][web:32]

1. De los objetivos nacionales a los logs de la realidad

En el informe SSVc anterior hablábamos de tres capas: datos, decisiones y eficacia. La metodología GQM obliga a formular, para cada capa, objetivos concretos (por qué), preguntas claras (qué queremos saber) y métricas específicas (con qué lo medimos). [web:24][web:19][web:33]

En el contexto nacional, los objetivos tienen nombres y apellidos:

- Disponer de datos SSVc fiables y oportunos (para no priorizar a ciegas). [web:19][web:22][web:25]
- Emitir decisiones coherentes y ejecutables, con plazos razonables. [web:6][web:24]
- Demostrar que la priorización basada en SSVc, KEV, EPSS y compañía reduce incidentes y exposición, especialmente en operadores sujetos a NIS2. [web:16][web:20][web:33][web:39]

La gracia de GQM es que no deja que las métricas nazcan por generación espontánea: cada cifra tiene que poder rastrearse hasta una pregunta y un objetivo que tenga sentido para el país, el regulador y los operadores.

2. Por qué no basta con “tener muchas métricas”

Una vez definidos objetivos y preguntas, la tentación siguiente es medir todo lo medible. Ahí entra PRAGMATIC, que nos recuerda nueve verdades incómodas:

- Una métrica puede ser técnicamente impecable y completamente irrelevante.
- O muy relevante, pero inaccionable (“sí, ya sé que vamos mal, ¿y ahora qué?”).
- O barata y rápida, pero manipulable hasta la caricatura. [web:27][web:32]

Calificar cada métrica SSVc contra los nueve criterios (Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente, Rentable) obliga a hacerse preguntas que no se responden con un gráfico bonito:

- ¿Esto anticipa algo o solo describe el pasado?
- ¿Alguien puede tomar decisiones concretas con este número?
- ¿Se puede mejorar este indicador sin hacer trampa?
- ¿Me cuesta más obtenerlo que lo que me aporta?

Cuando uno aplica este filtro, descubre que ciertas métricas muy llamativas —como el número bruto de CVE— tienen poco valor real, mientras que otras más técnicas —como el tiempo acumulado de exposición a KEV-Act— resultan incómodas pero extraordinariamente útiles. [web:25][web:12][web:6]

3. Ejemplos ilustrativos (para no quedar en la teoría)

Tomemos tres métricas y pasémoslas por el prisma combinado:

- **M1.1 – % de CVE relevantes con SSVC:** es barata, fácil de calcular y políticamente agradecida (“cada vez tenemos mejor cobertura de datos”). [web:19][web:22] Es relevante y accionable para el CERT nacional, pero tiene poco poder predictivo sobre incidentes; es una métrica de capacidad, no de resultado.
- **M5.2 – % de Act en plazo:** respira NIS2 por todos sus poros. Alinea objetivos nacionales, decisiones SSVC y comportamiento de operadores. [web:33][web:39] Tiene buen potencial predictivo (si nadie cumple los plazos, algo va a salir mal) y es claramente accionable; el riesgo está en su “genuinidad”: si redefinimos plazos para quedar bien, el indicador se convierte en decoración.
- **M7.1 – % de incidentes graves originados en Track/Attend:** es la métrica de la vergüenza honesta. [web:16][web:20][web:27] Requiere trabajo, análisis de incidentes y cierta humildad, pero es tremendamente significativa: mide hasta qué punto nuestro modelo SSVC está dejando pasar balas. No es barata ni inmediata, pero es difícil encontrar un indicador más genuinamente conectado con la realidad.

M1.1 – % de CVE relevantes con SSVC: es barata, fácil de calcular y políticamente agradecida (“cada vez tenemos mejor cobertura de datos”). [web:19][web:22] Es relevante y accionable para el CERT nacional, pero tiene poco poder predictivo sobre incidentes; es una métrica de capacidad, no de resultado.

M5.2 – % de Act en plazo: respira NIS2 por todos sus poros. Alinea objetivos nacionales, decisiones SSVC y comportamiento de operadores. [web:33][web:39] Tiene buen potencial predictivo (si nadie cumple los plazos, algo va a salir mal) y es claramente accionable; el riesgo está en su “genuinidad”: si redefinimos plazos para quedar bien, el indicador se convierte en decoración.

M7.1 – % de incidentes graves originados en Track/Attend: es la métrica de la vergüenza honesta. [web:16][web:20][web:27] Requiere trabajo, análisis de incidentes y cierta humildad, pero es tremendamente significativa: mide hasta qué punto nuestro modelo SSVC está dejando pasar balas. No es barata ni inmediata, pero es difícil encontrar un indicador más genuinamente conectado con la realidad.

Al final, un sistema nacional sano probablemente combinara unos cuantos indicadores de capacidad (cobertura SSVC, inventario), de actividad (volumen y distribución de decisiones, cumplimiento de plazos) y de resultado (incidentes, exposición, backlog), todos ellos seleccionados no por inercia sino porque superan una mínima puntuación PRAGMATIC.

4. Relación con NIS2 y supervisión

NIS2 exige, en esencia, tres cosas en este ámbito: saber qué activos y vulnerabilidades importan, gestionarlos con procesos continuos y tener algo sólido que mostrar cuando el regulador pregunta “¿y cómo sabe usted que lo está haciendo bien?”. [web:33][web:39][web:36]

El marco GQM+PRAGMATIC sirve para evitar dos extremos igualmente peligrosos:

- El minimalismo complaciente (“no medimos nada porque es complicado”).
- El maximalismo disperso (“medimos todo y no sabemos qué significa”).

Al vincular objetivos nacionales, preguntas regulatorias y métricas evaluadas por su valor práctico, se obtiene un conjunto razonable de indicadores que:

- Son auditables y explicables.
- No requieren una tesis doctoral para calcularse.
- Y, sobre todo, permiten tomar decisiones duras: dónde invertir más, a quién exigir más, qué parte del modelo SSVC hay que revisar. [web:27][web:32][web:33]

5. Cierre (sin moraleja moralizante)

Lo bueno de este enfoque es que, cuando dentro de unos años alguien pregunte por qué se eligieron ciertas métricas y no otras, habrá una respuesta menos vergonzosa que “porque estaban disponibles en la herramienta”. Habrá objetivos, preguntas y una matriz PRAGMATIC que expliquen que, al menos una vez, se intentó que los números sirvieran a la estrategia, y no al revés. [web:19][web:24][web:27][web:32][web:33]